

	MANUAL DE CALIDAD	MC413-IT-4
	Política de Contraseñas Seguras	REVISIÓN: 0 FECHA: 25/08/25
Emisión: G. MONTALBETTI Fecha: Firma:	Aprobación: D. PEDROSA Fecha: Firma:	PAG.: 1 / 5

1. OBJETIVO

Establecer los requisitos para la creación, gestión y protección de contraseñas en todos los sistemas de información de **PRODISMO SRL**. Esta política tiene como objetivo proteger el acceso no autorizado a los activos de información, garantizar la confidencialidad, integridad y disponibilidad de los datos, y cumplir con los requisitos de los controles A.5.17 (Autenticación), A.8.2 (Gestión de derechos de acceso) y A.8.3 (Responsabilidad del usuario por el acceso) del Anexo A de la norma **ISO/IEC 27001:2022**, así como con los requisitos de protección de información del marco **TISAX**.

2. ALCANCE

Esta política aplica a:

- **Todos los usuarios:** Empleados, contratistas, proveedores y terceros que tengan acceso a los sistemas de información de la organización.
- **Todos los sistemas:** Servidores, estaciones de trabajo, aplicaciones, bases de datos, servicios en la nube, dispositivos de red y cualquier otro sistema que requiera autenticación por contraseña.
- **Todos los dispositivos:** Equipos corporativos y personales (BYOD) utilizados para acceder a recursos de la empresa.

3. REFERENCIAS NORMATIVAS

- **ISO/IEC 27001:2022** - Anexo A.5.17 (Autenticación), A.8.2 (Gestión de derechos de acceso)
- **ISO/IEC 27002:2022** - Guía para los controles de seguridad
- Marco de evaluación **TISAX**
- Política de Control de Acceso **MC412-IT-1 Política de Autenticación y Control de Accesos**
- Documento **MC211-IT-2** Política de Uso Aceptable de Recursos de IT

	MANUAL DE CALIDAD	MC413-IT-4
	Política de Contraseñas Seguras	REVISIÓN: 0 FECHA: 25/08/25
		PAG.: 2 / 5

- Procedimiento de Contraseñas Seguras **P413-IT-2** Gestión de Contraseñas Seguras

4. DEFINICIONES

- **Contraseña Fuerte:** Contraseña que cumple con los requisitos de complejidad establecidos en esta política.
- **MFA (Autenticación Multifactor):** Método de autenticación que requiere dos o más pruebas de identidad.
- **Hash:** Función criptográfica utilizada para almacenar contraseñas de forma segura.
- **Gestor de Contraseñas:** Herramienta autorizada para almacenar y gestionar contraseñas de forma segura.

5. RESPONSABILIDADES

- **Alta Dirección:** Aprobar la política y asegurar los recursos para su implementación.
- **Responsable de Seguridad de la Información (RSI):** Mantener, supervisar y auditar el cumplimiento de esta política.
- **Departamento de IT:** Implementar controles técnicos para aplicar los requisitos de contraseñas (longitud, complejidad, caducidad) en todos los sistemas. Gestionar el acceso de usuarios y proporcionar gestores de contraseñas corporativos.
- **Responsables de Área:** Asegurar que el personal bajo su supervisión conoce y cumple esta política.
- **Todos los Usuarios:** Crear y proteger contraseñas fuertes, cumplir con los requisitos establecidos y reportar cualquier contraseña comprometida.

	MANUAL DE CALIDAD	MC413-IT-4
	Política de Contraseñas Seguras	REVISIÓN: 0 FECHA: 25/08/25
		PAG.: 3 / 5

6. REQUISITOS MÍNIMOS PARA CONTRASEÑAS

1. **Longitud Mínima:** 12 caracteres para usuarios standard. 16 caracteres para cuentas administrativas y de servicio.
2. **Complejidad:** Debe incluir caracteres de al menos tres de las siguientes cuatro categorías:
 - Letras mayúsculas (A-Z)
 - Letras minúsculas (a-z)
 - Números (0-9)
 - Caracteres especiales (ej: !, @, #, \$, %, &, *)
3. **Caducidad (Rotación):**
 - **Contraseñas de usuario:** 180 días. No se permite el reuso de las últimas 5 contraseñas.
 - **Contraseñas de administrador:** 90 días.
 - **Contraseñas de servicio/sistema:** Rotar anualmente o ante cualquier cambio en el personal responsable.
4. **Bloqueo de Cuenta:** Tras 5 intentos fallidos de inicio de sesión, la cuenta se bloqueará durante un período de 10 minutos.
5. **Almacenamiento:** Las contraseñas deben almacenarse en forma de **hash** con sal (salt) utilizando algoritmos fuertes (ej: bcrypt, Argon2). **Queda prohibido almacenar contraseñas en texto plano.**
6. **Autenticación Multifactor (MFA):** Es **obligatorio** el uso de MFA para:
 - Acceso remoto (VPN, escritorio remoto).
 - Acceso a sistemas críticos (ERP SIP 4.0, servidor de diseños 3D).
 - Todas las cuentas con privilegios administrativos.
 - Acceso a servicios en la nube (Microsoft 365, Azure, AWS).

	MANUAL DE CALIDAD	MC413-IT-4
	Política de Contraseñas Seguras	REVISIÓN: 0 FECHA: 25/08/25
		PAG.: 4 / 5

7. PROHIBICIONES

Queda **estrictamente prohibido**:

- **Compartir contraseñas:** Cada usuario es responsable de su contraseña. Bajo ninguna circunstancia se deben compartir las credenciales.
- **Reutilizar contraseñas:** No utilizar la misma contraseña para diferentes sistemas (corporativos y personales).
- **Almacenar contraseñas en claro:** No escribirlas en post-its, agendas, archivos de texto sin cifrar o emails.
- **Utilizar contraseñas débiles o comunes:** Ej: "Password123", "Welcome1", "123456", nombres de familiares o mascotas, fechas de cumpleaños.
- **Enviar contraseñas por canales no cifrados:** Como mensajes de texto SMS, WhatsApp no corporativo o correo electrónico sin cifrar.

8. GESTIÓN DE CONTRASEÑAS

- **Asignación Inicial:** Las contraseñas iniciales deben ser generadas de forma aleatoria y segura, y se deben cambiar en el primer inicio de sesión.
- **Recuperación:** El proceso de recuperación de contraseñas debe verificar la identidad del usuario a través de métodos alternativos seguros (preguntas de seguridad robustas, email alternativo, MFA). No se deben restablecer contraseñas por teléfono sin una verificación rigurosa.
- **Herramientas:** Se proporcionará y recomendará el uso de un **gestor de contraseñas corporativo** (ej: Bitwarden, Keeper) para almacenar y generar contraseñas fuertes.

	MANUAL DE CALIDAD	MC413-IT-4
	Política de Contraseñas Seguras	REVISIÓN: 0 FECHA: 25/08/25
		PAG.: 5 / 5

9. SANCIONES

El incumplimiento de esta política se considerará una violación de las normas de seguridad de la información y dará lugar a acciones disciplinarias, que podrán incluir, dependiendo de la gravedad de la infracción:

- **Amonestación verbal o escrita.**
- **Capacitación obligatoria** en seguridad de la información.
- **Suspensión** de los privilegios de acceso a los sistemas.
- **Desvinculación laboral** en casos graves o reincidentes que pongan en riesgo significativo la seguridad de la información.

10. REVISIÓN Y AUDITORÍA DEL DOCUMENTO

- Esta política será revisada **anualmente** por el RSI, o ante cambios en el panorama de amenazas o tecnologías.
- El cumplimiento de esta política se auditará mediante:
 - **Revisiones técnicas** de la configuración de los sistemas para verificar el cumplimiento de los requisitos de longitud, complejidad y caducidad.
 - **Simulaciones de phishing** para evaluar la concienciación de los usuarios.
 - **Auditorías internas** del **SGSI** y evaluaciones **TISAX**.
- Los resultados de las auditorías se presentarán a la Dirección.

11. REVISIONES DEL DOCUMENTO

Rev. N°	Fecha	Descripción
0	25/8/2025	Primera Emisión del documento